جامعة التقنية والعلوم التطبيقية
University of Technology and Applied Sciences
صحار
Suhar

Department of Information Technology

Midterm Exam

Academic Year: 2022-2023 **Semester: Spring**
Course Code: CSSY2108 **Date: 19/4/2023**
Course Title: Introduction to Security **Time: 11:00-11:40**

Student Name: _____

Student ID: _____ **Group No.:** _____

Instructions for students:

This exam lasts for **40 mins** and is worth **20% towards** your final mark for **CSSY2108**
Please, place all bags, folders and other belongings at the front or back of the room.
Please **TURN OFF** your mobile phones and leave them at the front or back of the room.
Please **DO NOT TALK** during the exam without permission from the invigilators.
Use **PEN** only to write your answers. **Calculators could be used.**
Hand in the exam paper to your invigilators, at the end of the exam.

For Examiner use only

	Mark allotted	**Mark scored**					
Section A Multiple choice (1 x 5)	**5**						
Section B Short Answer (3x3)	**9**	B1	B2	B3	B4	B5	
Section C long Answer (5x1)	**6**	C1					
Total	**20**						

Examiner: ..... Signature: .....

Section A: Multiple Choice Questions (5 Marks, each Question 1 mark)

A1. An interruption attack is a breach of _____

a. Availability
b. Authenticity
c. Confidentiality
d. Integrity

A2. Which one of the following may prevent a man-in-the-middle Attack?

a. Password-based authentication
b. Biometric authentication
c. Identity verification
d. Mutual authentication

A3. The _____dictates that we should only allow the bare minimum of access to a party—this might be a person, user account, or process—to allow it to perform the functionality needed of it.

a. principle of least privilege
b. Identity verification
c. Non-Repudiation
d. Authorization

A4. Which one of the following indicates an attack that misuses the authority of the browser on the user's computer?

a. Cross-site request forgery CSRF
b. Confused Assistant problem
c. Conflict of Interest
d. Discretionary access Control

A5. Which one of the following are created to link a public key to a particular individual and are often used as a form of electronic identification for that particular person?

a. Data Encryption Standard
b. Certificates
c. Digital Signatuer
d. RSA Algorithms

Section B: Short Answer Question: (9 Marks, each Question 3 marks) Please Answer only 3 Questions:

B1. List and explain the incident response process.

• **Preparation:** This involves having the policies and procedures that govern incident response and handling in place, conducting training.

• **Detection and analysis:** The detection and analysis phase is where the action begins to happen in our incident response process.

• **Containment:** To ensure that the situation does not cause any more damage than it already has.

• **Eradication :** Attempt to remove the effects of the issue from our environment.

• **Recovery:** recover to a better state that were in which we were prior to the incident.

• **Post incident activity -** we attempt to determine specifically what happened, why it happened, and what we can do to keep it from happening again.

B2. Define the characteristics of biometric factors

- **Universality - Able to find our chosen biometric, example, use a scar as an identifier**
- **Uniqueness - Unique a particular characteristic is among individuals. For example, if we choose to use height or weight**
- **Permanence - tests show how well a particular characteristic resists change over time and with advancing age**
- **Collectability - measures how easy it is to acquire a characteristic with which we can later authenticate a user.**
- **Performance - a set of metrics that judge how well a given system functions. Such factors include speed, accuracy, and error rate.**
- **Acceptability - measure of how acceptable the particular characteristic is to the users of the system.**
- **Circumvention - describes the ease with which a system can be tricked by a falsified biometric identifier.**

B3. Technician form OmanTel misbehave with customer when he deals with fixing the wireless access point at home fibre optic internet,

a. What ensures that they behave in accordance with the rules as they relate to security, business conduct, ethics, and so on.? (1.5 Marks) **Accountability**

b. What is the term we used to pervent the misbehaving technician? (1.5 Marks) **Detterrence**

B4. Define atleast two symmetric key algorithms in details.

DES – DES is a block cipher based on symmetric key cryptography and uses a 56-bit key.

3DES - 3DES (pronounced triple DES), which is simply DES used to encrypt each block three times, each time with a different key.

AES - AES is a set of symmetric block ciphers is the replacement for DES, AES uses three different ciphers: one with a 128-bit key, one with a 192-bit key, and one with a 256-bit key, all having a block length of 128 bits.

Section C: Long Answer: (6 Marks) Please Answer <u>only One</u> Question:

C1.Answer the following,

C1.1 List five steps involved in the risk management procedure [2 marks]

C1.2 Define authentication and list three different types of authentication factors

[4 marks]

Answer: (1 mark)

Authentication is, in an information security sense, the set of methods we use to establish a claim of identity as being true. It is important to note that authentication only establishes whether the claim of identity that has been made is correct.

(1 mark for any three)

- Something you know , such as passwords and PIN numbers
- Something you have, such as smart card or security token
- Something you are , such as fingerprint, voice retina , or iris

C2. Explain Network ACLs(2 Marks). Justify your answer how permit or deny email, File transfer and secure shell applications are using their port numbers to communicate.(Note : List Port Numbers used by these applications.)(4 Marks)

ACLs are regulating such activities that take place on networks. Permissions in network ACLs tend to be binary in nature, generally consisting of allow and deny.

Network Access controlled by

- **The identifiers we use for network transactions, such as Internet protocol (IP) addresses**

- **Media Access Control (MAC) addresses**
- **Ports.**

One of the simplest forms of network-oriented ACLs is MAC address filtering

- **It is a unique identifiers attached to each network interface in a given system.**

The other form of network-oriented ACLs is port being used to communicate over the network. Many common services and applications use specific ports to communicate over networks. For instance,

- **FTP uses ports 20 and 21 to transfer files,**
- **Internet Message Access Protocol (IMAP) uses port 143 managing e-mail**
- **Secure Shell (SSH) uses port 22 to manage remote connections to systems**